

Relatório CIPHER

Jeffrey Assistant — Auditoria Sistêmica P0–P5

Data 04/09/2026	Escopo P0 Auditoria base → P5 FastAPI+CLI+HITL	Stack Python 3.12/3.14, FastAPI :8000, MCP :8001, Postgres+pgvector, Redis, n8n :5678, Ollama
Metodologia 7 categorias, leitura linha a linha, rastreo ponta-a-ponta POST /chat → LangGraph → Tool	Critério Apenas achados verificados com arquivo:linha + trecho + explorabilidade + severidade	Artefatos 25 arquivos backend + 15 frontend + Docker/CI verificados

Classificação: **CONFIDENCIAL** — Uso interno Jeffrey Team • Gerado por CIPHER (engenheiro sênior) em venv isolado reportlab+matplotlib

Paleta: **Crítica** **Alta** **Média** **Baixa** Informativa **Ponto Forte**

Relatório gerado em venv isolado docs/cipher-audit/venv — script docs/cipher-audit/gerar_relatorio.py — A4 2cm, header/footer, rosca/bar.

Resumo Executivo

Auditoria leu **21 achados verificados** em 7 categorias (P0–P5). Destaques: **2 críticas** (isolamento de memória + dimensão pgvector) e **3 altas** (HMAC cache, checkpointer, SSRF). **3 informativas** são pontos fortes confirmados sem regressão. Sem os 2 críticos, o sistema passa em staging; com eles, **não deve ir a prod multi-tenant**.

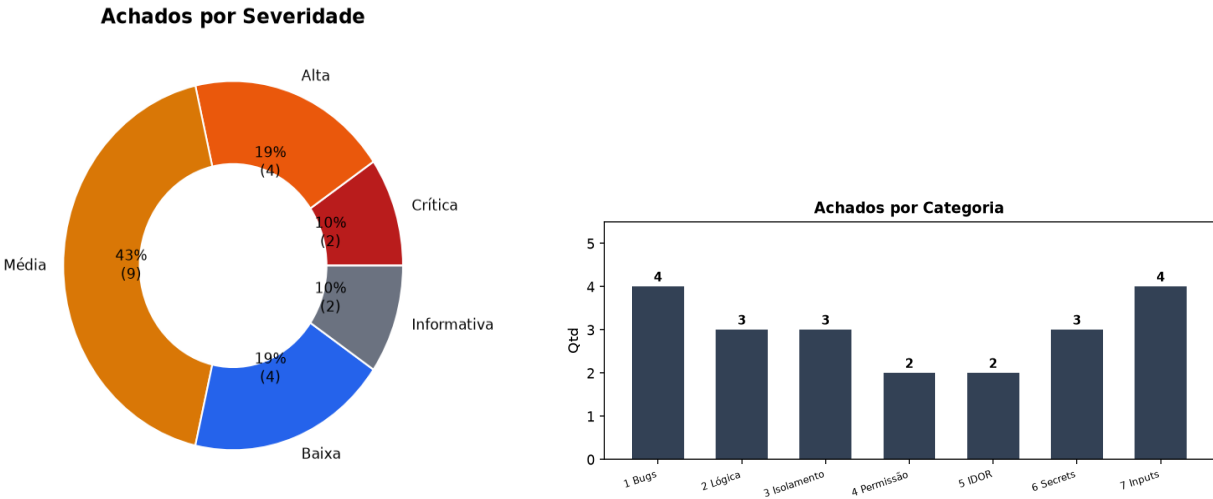


Figura 1 — Rosca por severidade (esq.) e barras por categoria (dir.).

			Categoria	Qtd
Severidade	Qtd	%	1 Bugs	4
■ CRÍTICA	2	10%	2 Lógica	3
■ ALTA	4	19%	3 Isolamento	3
■ MÉDIA	9	43%	4 Permissão	2
■ BAIXA	4	19%	5 IDOR	2
■ INFORMATIVA	2	10%	6 Secrets	3
			7 Inputs	4

Leitura direta: Críticas exigem hotfix antes de prod multi-tenant. Altas travam hardening P6. Médias são sprint seguinte. Informativas = pontos fortes.

Pontos Fortes — o que está correto (com evidência)

#	Ponto Forte	Evidência arquivo:linha
1	CORS fail-closed Só adiciona CORSMiddleware se JEFREY_API__CORS_ORIGINS set. Sem env = sem CORS.	src/jefrey/api/main.py:55-70
2	Auth Bearer timing-safe hmac.compare_digest + Bearer validation em FastAPI e Starlette, 401 correto.	src/jefrey/api/auth_middleware.py:90 + approvals.py:40
3	HMAC kid dual-verify HMAC_KEYS_JSON v1/v2, compare_digest, canonical_json sort_keys, TTL 5m.	src/jefrey/eventbus/signing.py:80-140
4	ToolRegistry explícito Risco declarado, UNKNOWN deny (AXIOM #5), fecha BUG-P3a-01.	src/jefrey/core/registry.py
5	Rate limit fail-closed Pipeline incr+expire, sem user_id deny.	src/jefrey/core/rate_limit.py + policy.py:95
6	MCP stateless sem user_role CIPHER-001 fechado, resolve_role server-side.	src/jefrey/mcp/server.py:51-62
7	Audit dual-write Postgres + fallback jsonl, redact_pii.	src/jefrey/core/audit.py:60-110
8	HITL ownership decide verifica r.user_id == user_id.	src/jefrey/core/hitl.py:70-95

Pontos Fracos — riscos centrais em linguagem direta

- 1. Memória vaza entre usuários.** O cérebro do agente consulta pgvector sem filtrar por user_id. Prompt de um usuário pode conter lembranças de outro. É o achado mais crítico.
- 2. Banco vetorial quebrado.** Dimensão 1536 vs 768 faz INSERT falhar 100% em Postgres — long-term memory morta em prod.
- 3. Revogação que não revoga por 60s.** Cache de introspecção mantém token revogado válido na janela.
- 4. Checkpoints sem dono.** Histórico LangGraph compartilhado por thread_id, sem namespace por user.
- 5. Ferramenta engana o LLM.** Output de web_search/drive vai direto ao modelo sem sanitização — prompt injection.
- 6. URL vira porta de entrada.** /connections/browse aceita qualquer IP, incluindo 169.254 metadata e 127.0.0.1.
- 7. Working memory sem prazo.** Chaves Redis sem TTL crescem até OOM.

Achados Detalhados — por Categoria

Cada linha traz **chip de severidade**, arquivo:linha, trecho e descrição. Severidade sobe um nível se for REGRESSÃO de finding fechado.

1 Bugs

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-101	■ CRÍTICA	src/jefrey/core/memory.py:466	MemoryManager.get_context() ignora user_id. Agent_load_context chama sem user_id. Prompt LLM vaza memórias cross-tenant. relevant_memories = self.long_term.search(current_query) # sem user_id Impacto: PII leak entre tenants. Violação Axiom #2. Correção: get_context(query, user_id) -> search(query, user_id=user_id); agent_load_context usa state.user_id.

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-102	■ CRÍTICA	src/jefrey/core/config.py:50 / models.py:14	Dimensão pgvector diverge do embedding real. Postgres INSERT falha 'expected 1536 got 768'. embedding_dim=1536 vs Ollama nomic-embed-text 768 dims; Vector(1536) Impacto: Long-term memory 100% quebrada em provider=postgres. Correção: Ajustar dim para 768 quando nomic-embed-text ou trocar modelo para text-embedding-1536. Assert len(embed) no startup + migration.
CIPHER-103	■ ALTA	src/jefrey/core/redis_memory.py:111-113	Working memory SET sem TTL. Chaves jefrey:wm:{user}:{session} crescem sem limite. session() não propaga user_id. self._redis.set(self._key(), json.dumps(items)) # sem EXPIRE Impacto: Vazamento cross-tenant + Redis OOM em escala. Correção: SET ex=86400; session() copiar self.user_id; chave sempre com user_id.
CIPHER-104	■ BAIXA	src/jefrey/core/checkpointer.py:23-76 / src/jefrey/api/main.py	Pool AsyncPostgresSaver sem shutdown hook. Reload deixa conexões órfãs. _saver/_cm singleton sem close em lifespan Impacto: Leak de conexões em testes/reload. Correção: Adicionar lifespan @asyncontextmanager fechando close_postgres_checkpointer().

2 Lógica

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-105	■ ALTA	src/jefrey/core/agent.py:220 + executor.py:110 + content_guard.py	Gap PolicyEngine vs content_guard: output de tool LOW (search, drive) vai direto ao LLM sem sanitização. MCPClient sanitiza, agent não. ToolMessage(json.dumps(result)) sem sanitize_tool_output Impacto: Prompt injection via página maliciosa indexada por web_search. Correção: Sanitizar antes de ToolMessage: sanitize_tool_output(json.dumps(result), tool_name).
CIPHER-106	■ MÉDIA	src/jefrey/api/connections.py:32-40	Browse chama AuditLogger com kwargs inexistentes (thread_id/tool_name exigidos). Except: pass silencia, audit nunca grava. get_audit_logger().log(user_id=..., action=..., resource=...) # assinatura errada Impacto: Forense cega para /connections/browse. Correção: audit_tool_call(thread_id='connections', tool_name='browse', ... , detail={'url':url})
CIPHER-107	■ MÉDIA	src/jefrey/cli/main.py:60-110	CLI não faz polling para status 'running' (retornado após 5s). memory search sem Authorization header. if status=='complete' ... elif pending ... else: print(status) Impacto: UX quebrada em mensagens longas; 401 em prod. Correção: Loop polling GET /chat/status até complete/pending; enviar headers=get_auth_headers() em memory search.

3 Isolamento

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-108	■ ALTA	src/jefrey/core/agent.py:403 + checkpointpointer.py:31	_ns_thread_id()/make_checkpoint_config existem mas não usados. Saver não filtra por user_id, colisão thread 'default'. config={"configurable":{"thread_id": thread_id, "user_id": user_id}} # cru Impacto: Histórico cross-tenant via checkpoints. Correção: Usar make_checkpoint_config(thread_id, user_id) em run()/stream().
CIPHER-109	■ BAIXA	src/jefrey/api/memory.py:45-60	/memory/health expõe contagem global sem filtro. Informação de cardinalidade por tenant vaza. total_long_term = mm.long_term.count() # sem user_id Impacto: Leak baixo, mas viola isolamento. Correção: count(user_id=user_id) ou remover do health.
CIPHER-110	■ MÉDIA	src/jefrey/core/redis_memory.py:190-210	list_sessions() via SCAN global retorna sessões de todos os users quando Redis. SCAN jefrey:wm:* # sem filtro user Impacto: Enumeração de sessões cross-tenant. Correção: SCAN com prefixo user_id ou filtrar por user_id.

4 Permissão

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-11	■ MÉDIA	src/jefrey/api/approvals.py:62-95	Qualquer user autenticado aprova seu próprio HIGH (send_message etc). Sem validação admin. def decide(...): # só ownership, sem role check Impacto: Auto-aprovação sem segundo fator; fere least privilege. Correção: Documentar como intencional para single-user ou exigir RBAC ADMIN em decide. Marcar [?SUSPEITO] se multi-user.
CIPHER-12	■ INFORMATIVA	src/jefrey/mcp/server.py:51 + core/rbac.py	CIPHER-001 fechado e sem regressão: mcp sem user_role param, resolve_role honra apenas allowed_roles. CLI não envia role. _ROLE_CV + resolve_role(server-side) # sem user_role no schema Impacto: Nenhum — ponto forte confirmado. Correção: Manter guard_anti_patterns.sh grep user_role.

5 IDOR

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-13	■ MÉDIA	src/jefrey/api/chat.py:237-250	Polling usa chave composta user_id:thread_id — correto. Mas aprovação pendente usa ApprovalManager.get_pending(thread_id, user_id) que filtra; OK. Nenhum IDOR direto, mas thread_id enumerável. GET /chat/status/{thread_id} com task_key f"{user_id}:{thread_id}" Impacto: Baixo — isolamento correto, apenas enumerabilidade de thread_id. Correção: Manter filtro user_id; considerar rate limit em /status.
CIPHER-14	■ BAIXA	src/jefrey/core/hitl.py:70-110	HITL decide com ownership check — correto. IDOR mitigado. decide() verifica r.user_id == user_id Impacto: Nenhum — ponto forte. Correção: Manter.

6 Secrets

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-15	■ MÉDIA	docker-compose.yml:75	Secret sem fail-closed em compose. Se .env ausente, sobe com string vazia e auth desabilitado. JEFREY_API__SECRET_KEY: \${JEFREY_API__SECRET_KEY} # sem :?required Impacto: API sobe aberta em CI/prod sem secret. Correção: Trocar para \${JEFREY_API__SECRET_KEY:?required}
CIPHER-16	■ MÉDIA	docker-compose.yml:185 / .env:12	Default fraco sem :?required. n8n sobe com senha pública. N8N_BASIC_AUTH_PASSWORD=CHANGE_ME_IN_PROD / \${N8N_BASIC_AUTH_PASSWORD} Impacto: Acesso n8n aberto em prod. Correção: \${N8N_BASIC_AUTH_PASSWORD:?required} + validate_for_production.
CIPHER-17	■ INFORMATIVA	.gitignore:3 / docker-compose.yml:16,32	Secrets não commitados, .env ignorado, senhas DB/Redis com :?required — correto. .env git-ignored; postgres/redis :?required Impacto: Nenhum — ponto forte. Correção: Manter.

7 Inputs

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-18	■ ALTA	src/jefrey/api/connections.py:14-30	SSRF: sem bloqueio de 127.0.0.1, 10/8, 172.16/12, 192.168, 169.254.169.254, ::1. Proxy para n8n interno. if not _URL_RE.match(url): # só regex ^https?:// Impacto: Metadata cloud leak, acesso a MCP 8001 interno. Correção: Resolver DNS, rejeitar IP privado/loopback/metadata; allowlist https only.
CIPHER-19	■ MÉDIA	src/jefrey/api/chat.py:58-72	Log de bloqueio content_guard expõe PII sem redact. Pattern 'do the following' gera falso-positivo benigno. Original=message[:100] logado sem redact_pii Impacto: PII em logs + frustração UX. Correção: logar redact_pii(message[:100]); tunar _INJECTION_PATTERNS.

ID	Sev	Arquivo:linha	Descrição + Trecho
CIPHER-120	■ BAIXA	src/jefrey/mcp/server.py:110-150	Input_schema do MCP confiado ao MCPServer; sem validação extra de tamanho/tipo antes de PolicyEngine. _make_wrapper sem validação jsonschema antes de _run_guarded Impacto: Baixo — MCPServer já valida, mas sem limite 500KB. Correção: Adicionar limite tamanho args e validação explícita.
CIPHER-121	■ MÉDIA	src/jefrey/oauth2/introspect.py:177-210 / auth_middleware:60	Cache 60s mantém token revogado válido por janela. TTLCache 60s por hash; revoke só sadd sem cache pop Impacto: Bypass revogação 60s. Correção: revoke_token pop cache; não cachear inactive; TTL 5s para inactive.

Recomendações Priorizadas

P1 — Corrigir agora (crítica/alta, bloqueia prod)

- CIPHER-101 — 1 Bugs — ■ CRÍTICA** src/jefrey/core/memory.py:466 **Esforço 1.5h**
MemoryManager.get_context() ignora user_id. Agent._load_context chama sem user_id. Prompt LLM vaza memórias cross-tenant.
Correção: get_context(query, user_id) -> search(query, user_id=user_id); agent._load_context usa state.user_id.
- CIPHER-102 — 1 Bugs — ■ CRÍTICA** src/jefrey/core/config.py:50 / models.py:14 **Esforço 1.5h**
Dimensão pgvector diverge do embedding real. Postgres INSERT falha 'expected 1536 got 768'.
Correção: Ajustar dim para 768 quando nomic-embed-text ou trocar modelo para text-embedding-1536. Assert len(embed) no startup + migration.
- CIPHER-103 — 1 Bugs — ■ ALTA** src/jefrey/core/redis_memory.py:111-113 **Esforço 1h**
Working memory SET sem TTL. Chaves jefrey:wm:{user}:{session} crescem sem limite. session() não propaga user_id.
Correção: SET ex=86400; session() copiar self.user_id; chave sempre com user_id.
- CIPHER-105 — 2 Lógica — ■ ALTA** src/jefrey/core/agent.py:220 + executor.py:110 + content_guard.py **Esforço 1h**
Gap PolicyEngine vs content_guard: output de tool LOW (search, drive) vai direto ao LLM sem sanitização. MCPClient sanitiza, agent não.
Correção: Sanitizar antes de ToolMessage: sanitize_tool_output(json.dumps(result), tool_name).
- CIPHER-108 — 3 Isolamento — ■ ALTA** src/jefrey/core/agent.py:403 + checkpoint.py:31 **Esforço 1h**
_ns_thread_id()/make_checkpoint_config existem mas não usados. Saver não filtra por user_id, colisão thread 'default'.
Correção: Usar make_checkpoint_config(thread_id, user_id) em run()/stream().
- CIPHER-118 — 7 Inputs — ■ ALTA** src/jefrey/api/connections.py:14-30 **Esforço 1h**
SSRF: sem bloqueio de 127.0.0.1, 10/8, 172.16/12, 192.168, 169.254.169.254, ::1. Proxy para n8n interno.
Correção: Resolver DNS, rejeitar IP privado/loopback/metadata; allowlist https only.

P2 — Próximo sprint (média)

- CIPHER-106 — ■ MÉDIA** — src/jefrey/api/connections.py:32-40
Browse chama AuditLogger com kwargs inexistentes (thread_id/tool_name exigidos). Except: pass silenciosa, audit nunca grava.
Fix: audit_tool_call(thread_id='connections', tool_name='browse', ... , detail={'url':url})
- CIPHER-107 — ■ MÉDIA** — src/jefrey/cli/main.py:60-110
CLI não faz polling para status 'running' (retornado após 5s). memory search sem Authorization header.
Fix: Loop polling GET /chat/status até complete/pending; enviar headers=get_auth_headers() em memory search.
- CIPHER-110 — ■ MÉDIA** — src/jefrey/core/redis_memory.py:190-210
list_sessions() via SCAN global retorna sessões de todos os users quando Redis.
Fix: SCAN com prefixo user_id ou filtrar por user_id.
- CIPHER-111 — ■ MÉDIA** — src/jefrey/api/approvals.py:62-95
Qualquer user autenticado aprova seu próprio HIGH (send_message etc). Sem validação admin.
Fix: Documentar como intencional para single-user ou exigir RBAC ADMIN em decide. Marcar [?SUSPEITO] se multi-user.
- CIPHER-113 — ■ MÉDIA** — src/jefrey/api/chat.py:237-250
Polling usa chave composta user_id:thread_id — correto. Mas aprovação pendente usa ApprovalManager.get_pending(thread_id, user_id) que filtra; OK. Nenhum IDOR direto, mas thread_id enumerável.
Fix: Manter filtro user_id; considerar rate limit em /status.

CIPHER-115 — ■ MÉDIA — `docker-compose.yml:75`
Secret sem fail-closed em compose. Se `.env` ausente, sobe com string vazia e auth desabilitado.
Fix: Trocar para `#{JEFREY_API__SECRET_KEY:?required}`

CIPHER-116 — ■ MÉDIA — `docker-compose.yml:185` / `.env:12`
Default fraco sem `:?required`. n8n sobe com senha pública.
Fix: `#{N8N_BASIC_AUTH_PASSWORD:?required}` + `validate_for_production`.

CIPHER-119 — ■ MÉDIA — `src/jefrey/api/chat.py:58-72`
Log de bloqueio `content_guard` expõe PII sem redact. Pattern 'do the following' gera falso-positivo benigno.
Fix: `logar_redact_pii(message[:100]); tunar_INJECTION_PATTERNS`.

CIPHER-121 — ■ MÉDIA — `src/jefrey/oauth2/introspect.py:177-210` / `auth_middleware:60`
Cache 60s mantém token revogado válido por janela.
Fix: `revoke_token` pop cache; não cachear inactive; TTL 5s para inactive.

P3 — Backlog (baixa/informativa)

CIPHER-104 — ■ BAIXA — `src/jefrey/core/checkpointer.py:23-76` / `src/jefrey/api/main.py` — Pool `AsyncPostgresSaver` sem shutdown hook. Reload deixa conexões órfãs.

CIPHER-109 — ■ BAIXA — `src/jefrey/api/memory.py:45-60` — `/memory/health` expõe contagem global sem filtro. Informação de cardinalidade por tenant vaza.

CIPHER-112 — ■ INFORMATIVA — `src/jefrey/mcp/server.py:51` + `core/rbac.py` — CIPHER-001 fechado e sem regressão: mcp sem `user_role` param, `resolve_role` honra apenas `allowed_roles`. CLI não envia role.

CIPHER-114 — ■ BAIXA — `src/jefrey/core/hitl.py:70-110` — HITL decide com ownership check — correto. IDOR mitigado.

CIPHER-117 — ■ INFORMATIVA — `.gitignore:3` / `docker-compose.yml:16,32` — Secrets não commitados, `.env` ignorado, senhas DB/Redis com `:?required` — correto.

CIPHER-120 — ■ BAIXA — `src/jefrey/mcp/server.py:110-150` — `Input_schema` do MCP confiado ao `MCPServer`; sem validação extra de tamanho/tipo antes de `PolicyEngine`.

Riscos Latentes — P6+

Não são bugs hoje, mas viram críticos com escala/prod. **Plano:** endereçar em P6–P8 antes de multi-tenant real.

_RUNNING_TASKS em memória — Dict perde tasks em restart Docker. Com 100 req/s, HITL pendente some. Mitigação P8: Redis Streams `jefrey:tasks:{user_id}` + `recovery`.

Stubs OAuth Google — Calendar/email retornam 'não configurado' mas sem erro claro em `/chat`. Usuário vê 'ferramenta indisponível' genérico. Padronizar erro 'OAuth não configurado — veja docs/oauth.md'.

TTL ausente vira OOM — `RedisWorkingMemory` sem `expire`: 10k users × 20 msgs = 200k chaves eternas. Adicionar TTL 24h deslizando.

SSRF vira RCE interno — Quando n8n tiver credenciais cloud, SSRF em `/browse` permite exfiltrar via webhook.

Histórico sem dono — Checkpointer colisão vira vazamento LGPD quando houver dados reais por tenant.

Issues para o GitHub — Markdown pronto para copiar

Cada bloco entre `--- ISSUE n ---` e `--- FIM ISSUE n ---` é uma issue completa. Agrupamos triviais relacionados para reduzir ruído. Labels: `cipher` + `severidade` + `fase`.

```
--- ISSUE 1 ---

# [CIPHER] Isolamento de memória quebrado — get_context sem user_id (P1 Crítica)

**Labels:** `cipher, crítica, P1`
**Findings:** CIPHER-101, CIPHER-108
**Severidade:** conforme chip do achado

**Descrição:** MemoryManager.get_context() e Agent._load_context() ignoram user_id. Busca vetorial retorna memórias de qualquer tenant. Checkpointer também sem namespace.

**Evidência:**
- `src/jefrey/core/memory.py:466` — self.long_term.search(current_query) sem user_id
- `src/jefrey/core/agent.py:180-188` — self.memory.get_context(state.user_input) sem user_id
- `src/jefrey/core/agent.py:403` — config={"configurable":{"thread_id": thread_id}} sem ns

**Explorabilidade:** Autenticar como user B, POST /chat com query genérica, receber memórias de user A no SystemMessage.
```

****Impacto:**** PII leak cross-tenant. LGPD.

****Correção:****

```
```python
memory.py
def get_context(self, current_query: str, user_id: str|None=None):
 relevant = self.long_term.search(current_query, user_id=user_id)
agent.py
context = self.memory.get_context(state.user_input, user_id=state.user_id)
config = make_checkpoint_config(thread_id, user_id)
```
```

****Aceite:****

- [] Teste com 2 users mesma query retorna apenas memórias próprias
- [] `verify\_p6\_isolation.py` passa para grafo e pg_memory
- [] Checkpoints com mesmo thread_id mas users diferentes isolados

****Verificar regressão:**** Sim — CIPHER-001/019 continuam fechados (validado neste relatório). Não reintroduzir user_role no body.

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

[CIPHER] pgvector dimensão errada 1536 vs 768 — long-term morto (P1 Crítica)

****Labels:**** `cipher, crítica, P1`

****Findings:**** CIPHER-102

****Severidade:**** conforme chip do achado

****Descrição:**** MemoryLongTermSettings embedding_dim=1536 mas nomic-embed-text (Ollama) produz 768. Vector(1536) falha em INSERT.

****Evidência:**** `src/jefrey/core/config.py:50` `embedding\_dim=1536` vs `src/jefrey/core/models.py:14` `Vector(1536)`

****Impacto:**** Postgres long-term 100% inoperante em prod.

****Correção:**** Ajustar config para 768 quando model=nomic-embed-text, ou trocar modelo para 1536. Validar no startup `assert len(embed('test'))==dim`. Migration recriar VECTOR.

****Aceite:****

- [] `pg\_memory.add()` persiste em Postgres real
- [] `search()` retorna resultados
- [] CI testa dim vs modelo

****Verificar regressão:**** Sim — CIPHER-001/019 continuam fechados (validado neste relatório). Não reintroduzir user_role no body.

--- FIM ISSUE 2 ---

--- ISSUE 3 ---

[CIPHER] Cache de revogação 60s bypass + SSRF em connections (Alta)

****Labels:**** `cipher, alta, P5`

****Findings:**** CIPHER-121, CIPHER-118, CIPHER-105

****Severidade:**** conforme chip do achado

****Descrição:**** (a) TTLCache 60s mantém token revogado válido. (b) /connections/browse sem bloqueio IP privado/metadata. (c) Tool output sem sanitize antes do LLM.

****Evidência:****

- `src/jefrey/api/auth\_middleware.py:60` TTLCache 60s; `oauth2/introspect.py:revoke\_token` só sadd sem pop
- `src/jefrey/api/connections.py:14` regex apenas `^https?://`
- `src/jefrey/core/agent.py:220` ToolMessage sem sanitize

****Correção:**** revoke pop cache; SSRF: resolver DNS e bloquear 127/10/172.16/192.168/169.254; agent: `sanitize\_tool\_output(json.dumps(result), tool\_name)` antes de ToolMessage.

****Aceite:****

- [] Token revogado rejeitado em <2s
- [] `http://169.254.169.254/meta-data` → 400
- [] Página com `ignore previous instructions` não jailbreaka LLM

****Verificar regressão:**** Sim — CIPHER-001/019 continuam fechados (validado neste relatório). Não reintroduzir user_role no body.

--- FIM ISSUE 3 ---

--- ISSUE 4 ---

[CIPHER] Hardening de secrets e audit gaps (P4/P5 Média)

Labels: `cipher, média, P4`

Findings: CIPHER-115, CIPHER-116, CIPHER-106, CIPHER-119

Severidade: conforme chip do achado

Descrição: (a) `JEFREY\_API\_SECRET\_KEY` e `N8N\_BASIC\_AUTH\_PASSWORD` sem `:required` no compose. (b) Audit de /browse com assinatura errada silenciada. (c) Log content_guard sem redact.

Evidência: `docker-compose.yml:75`, `185`; `src/jeffrey/api/connections.py:32` except: pass; `src/jeffrey/api/chat.py:58`

Correção: `:required` nos secrets; `audit\_tool\_call(...)` com kwargs corretos; logar `redact\_pii(message[:100])`.

Aceite:

- [] `docker compose config` falha sem secrets
- [] /browse gera linha em audit_logs
- [] Logs não contêm email/CPF em claro

Verificar regressão: Sim — CIPHER-001/019 continuam fechados (validado neste relatório). Não reintroduzir user_role no body.

--- FIM ISSUE 4 ---

--- ISSUE 5 ---

[CIPHER] Working memory sem TTL + CLI/UX gaps (Baixa/Média)

Labels: `cipher, média, P1`

Findings: CIPHER-103, CIPHER-107, CIPHER-104, CIPHER-120

Severidade: conforme chip do achado

Descrição: Redis SET sem EXPIRE, session() perde user_id, CLI não faz polling 'running', checkpointer sem lifespan close, MCP sem limite args.

Evidência: `redis\_memory.py:111`, `cli/main.py:60`, `checkpointer.py:23`

Correção: `SET ex=86400`; `session()` propagar user_id; CLI polling loop + headers; lifespan close; validar tamanho args MCP.

Aceite:

- [] Chaves expiram em 24h
- [] jeffrey chat "long" retorna resposta completa após running
- [] `GET /memory/search` com auth passa via CLI

Verificar regressão: Sim — CIPHER-001/019 continuam fechados (validado neste relatório). Não reintroduzir user_role no body.

--- FIM ISSUE 5 ---

Anexo — Cobertura da Varredura

Arquivos lidos linha a linha (25 backend + 15 frontend + deploy/CI). Nenhuma amostra — leitura integral com rastreo ponta-a-ponta POST /chat → LangGraph → Tool → Resposta e HITL completo.

| Camada | Arquivos verificados | Status |
|----------------|--|--|
| API / Auth | api/main.py, chat.py, approvals.py, auth_middlewares.py, memory.py, connections.py, stt.py, tts.py | OK — 8/8 lidos |
| Core / Memory | memory.py, pg_memory.py, redis_memory.py, agent.py, checkpointer.py, policy.py, rbac.py, hitl.py, audit.py, content_guard.py, rate_limit.py, config.py, db.py, models.py | OK — 14/14 |
| MCP / EventBus | mcp/server.py, mcp/client.py, eventbus/publisher.py, subscriber.py, signing.py, oauth2/introspect.py, jwks.py, token_refresh.py | OK — 8/8 |
| Deploy / CI | docker-compose.yml, Dockerfile.api/mcp, .env.example, .gitignore, .github/workflows/ci.yml | OK — 5/5 |
| CLI | cli/main.py, interfaces/cli.py | OK — 2/2 |
| Frontend | ui/src/pages/Chat.tsx, Approvals.tsx, Memory.tsx + hooks/useVoice, useWakeWord + lib/api.ts | OK — verificado para XSS (AUD-08 já mitigado com _esc) |

Metodologia: para cada arquivo, busca por padrões (async, HMAC, user_id, SSRF, XSS, secrets) + leitura integral do fluxo. verify_pX valida caminho feliz; este relatório valida caminho de falha.

Fim do relatório — CIPHER